

Informe de Cumplimiento - Seguridad y Operaci3n

1. HTTPS/TLS

- Certificados dev: `scripts/security/generate-dev-cert.sh` (autofirmado dev.local/127.0.0.1).
- Redirecci3n HTTP?HTTPS: definida en `services/api-gateway/nginx.conf`.
- Headers de seguridad: HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, X-XSS-Protection, CSP en `services/api-gateway/nginx.conf`.
- Documentaci3n: ver README (secci3n Infraestructura/HTTPS) y `docs/hardening-contenedores.md`.
- [ESPACIO PARA PANTALLAZOS/PRUEBAS] `curl -I http://localhost:8080 -> Location: https://...`

2. Hardening de Contenedores

- Usuarios no privilegiados: servicios Node y DB-proxy/Grafana/Loki/etc. usan usuarios no root; excepci3n: gateway/frontends corren como root para evitar chown en `/var/cache/nginx` (justificado en `docs/hardening-contenedores.md`).
- Configuraciones de seguridad: `security_opt: no-new-privileges` y `cap_drop: [ALL]` aplicadas a backends, gateway (quitado temporalmente en nginx), monitoreo; rate limiting en gateway.
- Multi-stage builds: servicios Node usan multi-stage con `node:18.18.2-alpine`.
- Escaneo de vulnerabilidades: [PENDIENTE] agregar reporte (gitleaks/trivy/grype). Espacio reservado.
- Documentaci3n: `docs/hardening-contenedores.md`.

3. Hardening de Bases de Datos

- Autenticaci3n/privilegios m3nimos: rol APP con m3nimos en `infrastructure/database/02-hardening.sh`; usuario de replicaci3n configurado.
- Aislamiento de red: redes separadas (frontend/backend/database) en `docker-compose.yml`; Postgres no expone al host.
- Logging/auditor3a: pendiente integraci3n de logs DB en Loki; proxy HAProxy con healthchecks. [PENDIENTE] a3adir query/logs espec3ficos DB.
- Documentaci3n: `docs/hardening-database.md`.

4. Gest3n de Secretos

- Sistema: variables v3a `.env`, `.env.example` con placeholders fuertes; compose sin credenciales hardcodeadas.
- Script de rotaci3n: `scripts/security/rotate-secrets.sh` (genera DB/APP DB/Redis/JWT/SMTP/API keys/Grafana/replicaci3n).
- Sin credenciales en Git: `.env` ignorado; verificar historial con gitleaks/trufflehog (pendiente ejecutar reporte).
- Documentaci3n: README (Gesti3n de secretos).

5. WAF y Seguridad de Red

- WAF/Rate limiting: en `services/api-gateway/nginx.conf` (`limit_req`, bloqueo de UAs comunes, m3todos permitidos, headers). Logs JSON no; se usa formato access log.
- Segmentaci3n de redes: `frontend-network`, `backend-network`, `database-network` en compose.

- Pruebas de bloqueo: [PENDIENTE] incluir salidas/ capturas de curl 403 (UA) y 429 (rate limit) + extractos de logs.

6. Análisis de Vulnerabilidades

- Reportes: [PENDIENTE] adjuntar resultados de gitleaks/trivy/grype.
- Documento de remediación: [PENDIENTE] listar hallazgos y acciones.
- Script automatizado: [PENDIENTE] añadir script (ej. [scripts/security/scan.sh](#)).

7. Logging y Auditoría

- Sistema: Loki + Promtail + Grafana; [promtail-config.yml](#) etiqueta contenedores y filtra eventos de seguridad (401/403 en gateway, JSON app).
- Eventos registrados: 401/403 gateway; cualquier evento app logueado en JSON con status/path/user. [PENDIENTE] capturas de dashboard/queries en Grafana.
- Script de consulta: [scripts/security/query-logs.sh](#).
- Documentación: [docs/logging-seguridad.md](#).

8. Documentación y Políticas

- Documentos: README actualizado; [docs/hardening-contenedores.md](#), [docs/hardening-database.md](#), [docs/logging-seguridad.md](#).
- Políticas/pasos operativos: README (arranque, secretos, logging). [PENDIENTE] añadir políticas formales si las requiere la r brica.

Notas operativas

- Gateway/frontends corren como root por limitaci n de la imagen nginx (chown en [/var/cache/nginx](#)). Opciones de endurecimiento en [docs/hardening-contenedores.md](#).
- Pruebas y capturas: marcar como pendiente; colocar evidencias en cada secci n cuando se ejecuten.